

FFUF Practical Commands & Examples Guide

This guide contains practical FFUF commands with real example URLs, brief explanations, and expected outputs for CTFs and web pentesting labs.

1. Basic Directory Discovery

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt
```

What it does: Searches for hidden directories and files on the target website.

Expected Result: Finds paths like /admin, /backup, /uploads.

2. PHP File Discovery

Command:

```
ffuf -u http://example.com/FUZZ.php -w raft-small-files.txt
```

What it does: Looks for hidden PHP files.

Expected Result: Returns valid files such as login.php or config.php.

3. Subdomain Discovery

Command:

```
ffuf -u http://FUZZ.example.com -w subdomains.txt
```

What it does: Discovers subdomains using DNS or virtual host responses.

Expected Result: May reveal dev.example.com or api.example.com.

4. Virtual Host Discovery

Command:

```
ffuf -u http://10.10.10.5 -H 'Host: FUZZ.example.com' -w subdomains.txt
```

What it does: Finds hidden virtual hosts hosted on the same server.

Expected Result: Detects admin.example.com or internal.example.com.

5. GET Parameter Discovery

Command:

```
ffuf -u 'http://example.com/index.php?FUZZ=test' -w params.txt
```

What it does: Searches for hidden GET parameters.

Expected Result: Finds parameters like debug, file, or page.

6. POST Parameter Discovery

Command:

```
ffuf -X POST -d 'FUZZ=test' -u http://example.com/login -w params.txt
```

What it does: Finds hidden POST parameters accepted by forms.

Expected Result: Discovers parameters such as username or token.

7. JSON API Fuzzing

Command:

```
ffuf -X POST -H 'Content-Type: application/json' -d '{"FUZZ":"admin"}' -u http://api.example.com/login -w param
```

What it does: Fuzzes JSON API parameters.

Expected Result: Finds valid JSON fields accepted by the API.

8. Match Only 200 Responses

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt -mc 200
```

What it does: Displays only successful HTTP 200 responses.

Expected Result: Reduces noise and highlights valid pages.

9. Filter 404 Errors

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt -fc 404
```

What it does: Hides HTTP 404 responses.

Expected Result: Cleaner output with useful results only.

10. Filter By Response Size

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt -fs 1234
```

What it does: Filters responses with identical sizes.

Expected Result: Removes wildcard or fake responses.

11. Recursive Scanning

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt -recursion
```

What it does: Automatically scans discovered directories recursively.

Expected Result: Deep enumeration of nested folders.

12. Multi-Wordlist Fuzzing

Command:

```
ffuf -u http://example.com/FUZZ1.FUZZ2 -w dirs.txt:FUZZ1 -w ext.txt:FUZZ2
```

What it does: Uses multiple wordlists simultaneously.

Expected Result: Finds combinations like admin.php or backup.zip.

13. Cookie Authenticated Scan

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt -H 'Cookie: PHPSESSID=abcd1234'
```

What it does: Scans authenticated sections of the application.

Expected Result: Accesses hidden logged-in resources.

14. Burp Suite Replay Proxy

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt -replay-proxy http://127.0.0.1:8080
```

What it does: Sends matching requests to Burp Suite.

Expected Result: Allows manual inspection of interesting responses.

15. Save Results as JSON

Command:

```
ffuf -u http://example.com/FUZZ -w common.txt -o results.json -of json
```

What it does: Exports results into JSON format.

Expected Result: Creates a structured results.json report.
